Minor Project Assessment: Vulnerability Assessment, API Testing & Forensics

Student: [Your full name]

Program: Cyber Security Program — Unlox (edit if needed)

Date: [DD Month YYYY]

Environment: Authorized bWAPP/bee-box and PortSwigger Web Security Academy labs

Evidence integrity statement: This report distinguishes recorded lab observations from test plans and unperformed forensic work. No instructor-provided forensic image/log bundle was available when this report was prepared. Therefore, Q6 includes a reproducible Autopsy workflow and templates, but no invented hashes, artifacts, timestamps, or case-specific conclusions. Online Autopsy screenshots linked below are tool references, not evidence from this investigation.

Executive Summary

This assessment covers web vulnerability testing, API reconnaissance and security test planning, and a digital-forensics workflow. In the local bWAPP/bee-box lab, searching for `man` returned `Iron Man`; a single quote produced an error; and the Boolean-style input `' OR 1=1 -- -` returned multiple/all records. The behavior is consistent with SQL injection in the tested search input. Submitting the harmless payload `<script>alert(1)</script>` caused a JavaScript alert to appear, consistent with script execution in the tested page context.

For API reconnaissance, the authorized PortSwigger API documentation lab exposed API documentation, and the lab objective was completed by deleting the designated lab user `carlos`. This does not, by itself, prove BOLA or arbitrary user deletion. An access-control lab was also reported as completed, but the exact request/response evidence was not available for this report, so no specific authorization vulnerability is asserted. Q5 is a test plan, not a set of confirmed findings. Q6 remains pending the actual instructor-provided evidence image or logs.

1. Scope and Rules of Engagement

In scope: SQLi and XSS testing in the authorized vulnerable web lab; API documentation/endpoint mapping; object-level authorization testing methodology; controlled API input/security-control test planning; and digital-forensics workflow using Autopsy or FTK Imager.

Out of scope: public/third-party targets without authorization, destructive tests, denial of service, persistence, malware deployment, or access to real users' data.

Recorded lab addresses: bee-box/bWAPP `http://10.0.2.6/`; separate Metasploitable 2 practice VM `10.0.2.4`. API work used authorized PortSwigger Web Security Academy labs. These are training-lab details only.

2. Methodology

1. Establish target authorization and baseline behavior.
2. Change one input/request property at a time.
3. Compare normal and test behavior.
4. Preserve genuine screenshots and sanitized request/response evidence.
5. Describe observed facts separately from inference.
6. Rate impact proportionately and recommend remediation.
7. For forensics, preserve originals, verify hashes, analyze a working copy, correlate artifacts, and document limitations.

3. Q1 — SQL Injection in bWAPP (15 marks)

Recorded observations

| Test | Input | Observation | Interpretation |

| --- | --- | --- | --- |

| Baseline | `man` | Result included `Iron Man` | Normal search baseline |

| Error probe | `'` | Error appeared | Supporting clue, not sufficient alone |

| Boolean-style probe | `' OR 1=1 -- -` | Multiple/all records appeared | Strong behavior consistent with SQL injection |

Finding Q1-01 — SQL injection in tested search input

Provisional severity: High, depending on database privileges and data sensitivity.

Status: Behavior consistent with SQLi based on the recorded lab observation.

The Boolean-style input appears to alter the query logic instead of being handled purely as data. Potential impact can include unauthorized record retrieval and, depending on query/privileges, modification or authentication bypass; these broader impacts were not demonstrated by the observations recorded here.

Remediation: Use parameterized queries/prepared statements; avoid SQL string concatenation; apply least-privilege database permissions; return generic client errors; log details securely; and add regression tests.

Evidence to add: `Evidence/Q1_01_baseline_search.png`, `Q1_02_single_quote_error.png`, `Q1_03_boolean_test.png`. The observations were reported from the lab session, but these screenshots were not included in the materials used to prepare this report. Add genuine captures and exact URL/parameter details.

4. Q2 — Cross-Site Scripting in bWAPP (15 marks)

Recorded observation

Submitting `<script>alert(1)</script>` in the authorized lab caused a JavaScript alert displaying `1`.

Finding Q2-01 — Script execution consistent with XSS

Provisional severity: Medium–High depending on context and audience.

Status: Script execution was reported; exact URL/parameter and persistence behavior need to be documented to classify the subtype confidently.

If it executes only in the immediate response, it is consistent with reflected XSS. If it persists and executes for later visitors, it may be stored XSS. Do not call it stored XSS unless persistence was tested.

Potential impact: XSS can allow page manipulation or actions in a victim's authenticated browser context, depending on the application and browser protections. It does not automatically imply that HttpOnly cookies can be read.

Remediation: Use context-aware output encoding; prefer safe DOM APIs such as `textContent` over unsafe HTML insertion; sanitize rich HTML with a maintained allow-list sanitizer when necessary; and deploy a restrictive Content Security Policy as defense in depth.

Evidence to add: `Evidence/Q2_01_payload_input.png`, `Q2_02_alert_execution.png`, `Q2_03_response_or_page_context.png`.

5. Q3 — API Reconnaissance and Endpoint Mapping (10 marks)

The authorized PortSwigger Web Security Academy lab “Exploiting an API endpoint using documentation” was used. API documentation was found and the lab objective was completed by deleting the designated lab user `carlos` through the lab workflow.

Interpretation: This demonstrates discoverable API documentation and completion of that lab objective. It does not by itself prove BOLA, authentication bypass, or arbitrary user deletion outside the lab.

Endpoint map — complete from actual documentation/HTTP history

| Route | Method | Parameters/body | Auth | Status/response | Purpose/notes |

| --- | --- | --- | --- | --- | --- |

| `[copy exact route]` | `[method]` | `[fields]` | `[required/none/unknown]` | `[observed]` | `[purpose]` |

| `[copy exact route]` | `[method]` | `[fields]` | `[required/none/unknown]` | `[observed]` | `[purpose]` |

| `[copy exact route]` | `[DELETE/etc.]` | `[object identifier]` | `[lab session/auth]` | `[observed]` | `[lab action]` |

Method: list routes and supported methods; record headers/cookies, path/query parameters and JSON fields; send only low-impact lab requests; compare documentation with observed traffic; record content type/status/body shape; and save sanitized request/response evidence.

Finding Q3-01: API documentation/attack-surface discovery. **Severity:** Informational–Low unless sensitive functionality is exposed without proper controls. Documentation can be public by design; sensitive operations must still enforce server-side authorization.

Evidence to add: `Q3_01_api_documentation.png`, `Q3_02_endpoint_request_response.png`, `Q3_03_lab_completion.png`.

6. Q4 — API Authorization Testing (15 marks)

Controlled test procedure

1. Authenticate as User A and capture a legitimate request for User A's own object.
2. Record route, method, object identifier, session/token, and response.
3. In the authorized lab only, change only the identifier to the known test object for User B.
4. Keep User A's session unchanged; do not substitute User B's token.
5. Compare response code, returned object fields, and whether an action actually occurred.
6. Save both requests and responses.

Evidence interpretation: A flaw is supported if User A receives User B's protected object or performs a protected action without authorization. A `200` alone is insufficient; inspect the response and actual effect. A denial or ambiguous response does not confirm a flaw.

The student reported completing an access-control lab, but the exact request/response pair was not available to this report. Consequently, no confirmed BOLA/IDOR finding is asserted here.

Remediation if confirmed: enforce server-side object-level authorization on every operation; validate ownership against the authenticated principal; deny by default; do not rely on hidden or unpredictable IDs; and add cross-user read/update/delete regression tests.

Evidence to add: `Q4_01_userA_baseline_request.png`, `Q4_02_modified_object_id.png`, `Q4_03_comparison_response.png`.

7. Q5 — API Input and Security Controls Test Plan (15 marks)

Status: Plan only; no outcomes are claimed unless actual evidence is added.

Test area	Controlled test	Weakness tested	Evidence of a weakness
Input validation/types	Wrong JSON type; negative quantity only where schema says non-negative	Weak type/business validation	Invalid value is accepted and causes incorrect processing/state
Unexpected fields/mass assignment	Add one undocumented field to a lab-owned test object	Unsafe binding of client-supplied fields	Protected field changes despite not being in allowed schema
Authentication/session	Repeat protected request without cookie/token and with invalid/expired token	Missing authentication enforcement	Protected data/action succeeds without valid auth
Rate limiting	Small, controlled series of repeated read requests, respecting lab rules	Missing abuse controls	No expected throttling on sensitive/costly actions; record rate/window
HTTP methods	Check `OPTIONS` and documented methods; avoid destructive payloads	Unnecessary methods or inconsistent access control	Unexpected method works or bypasses controls
Error handling	Malformed JSON or wrong Content-Type	Verbose/internal errors	Stack traces, paths, secrets, SQL/internal details exposed
Excessive data exposure	Inspect raw JSON for test account/object	Overly broad response	Sensitive/unneeded fields returned to caller

Test discipline: use only authorized endpoints/accounts; change one variable per request; avoid brute force, high volume, and destructive methods; save sanitized request/response evidence; and do not label a control failed merely because a response differs.

General remediation: server-side schema validation, allow-listed fields, strong authentication and object authorization, per-user/per-route rate limits, method allow-lists, generic client errors, structured logs, and response objects containing only necessary fields.

8. Q6 — Disk/File Forensics with Autopsy (15 marks)

Evidence limitation

The assignment requires an instructor-provided forensic image/evidence set. No such image or log bundle was available while preparing this report. Therefore, no case-specific artifact, hash, suspicious file, timestamp, or timeline entry can responsibly be claimed. The steps below are ready to execute when the evidence is obtained.

Preservation and hash verification

Record evidence ID, source, acquisition date/method, size, and custody details. Preserve the original as read-only and analyze a working copy. Calculate SHA-256 before analysis and verify it after copying/transferring.

```
sha256sum /path/to/instructor-image.E01
stat /path/to/instructor-image.E01
file /path/to/instructor-image.E01
```

If evidence arrives as a ZIP, hash the original ZIP first, extract to a separate working directory, and record filenames and hashes of extracted files.

Autopsy workflow

1. Launch Autopsy and create a case with a neutral name and investigator details.

2. Choose **Add Data Source** and select the instructor image or logical evidence set.

3. Record image type/source path; do not modify the original.

4. Enable applicable ingest modules: file type identification, hash calculation/lookup (if a suitable known-file set is configured), keyword search, recent activity/web artifacts, EXIF parsing, and metadata analysis.

5. Wait for ingest completion; record Autopsy version, modules, and status.

6. Review file system, deleted files, browser history/downloads, recent documents, archives, executables, logs, user activity, and relevant metadata.

7. Open Timeline, correlate filesystem and parsed events, and record timezone and source for each timestamp.

8. Bookmark relevant artifacts and export a report. Hash exported evidence where appropriate.

Official Autopsy documentation describes ingest modules for hash calculation/lookup, keyword search and web artifact extraction, and the Timeline feature for chronological event correlation.

Evidence log — fill with real values

| Evidence ID | Item/path | Source | SHA-256 | Size | Handling notes |

| --- | --- | --- | --- | --- | --- |

| E-01 | `[image filename]` | `[instructor/source]` | `[actual hash]` | `[actual size]` | `[original/working copy]` |

| E-02 | `[exported artifact]` | `[Autopsy result]` | `[actual hash if exported]` | `[actual size]` | `[export method]` |

Artifact table — fill from Autopsy

| Artifact ID | Path/type | Timestamp + timezone | Hash/metadata | Observed fact | Interpretation/confidence |

| --- | --- | --- | --- | --- | --- |

| A-01 | `[actual artifact]` | `[actual value]` | `[actual metadata]` | `[what Autopsy shows]` | `[fact vs hypothesis]` |

| A-02 | `[actual artifact]` | `[actual value]` | `[actual metadata]` | `[what Autopsy shows]` | `[fact vs hypothesis]` |

Timeline template

| Time + timezone | Event | Source | Observed fact | Significance | Confidence |

| --- | --- | --- | --- | --- | --- |

| `[actual timestamp]` | `[actual event]` | `[file/log/browser artifact]` | `[direct observation]` | `[why it matters]` | `[reasoned confidence]` |

Do not populate the timeline with guessed dates or example incidents.

Forensic conclusion

Current status: Incomplete pending evidence acquisition. No conclusion about unauthorized activity is supportable without the instructor's image/logs. Once available, report only observed artifacts, consider alternative explanations, and state limitations.

Autopsy reference images — illustrative only

These official pages contain Autopsy UI screenshots and are for learning the tool, not evidence from this case:

• [Autopsy Quick Start Guide](https://sleuthkit.org/autopsy/docs/user-docs/4.12.0/quick_start_guide.html)

• [Autopsy Ingest Modules](https://sleuthkit.org/autopsy/docs/user-docs/4.21.0/ingest_page.html)

• [Autopsy Timeline](https://sleuthkit.org/autopsy/docs/user-docs/4.16.0/timeline_page.html)

9. Q7 — Scenario-Based Incident Investigation (15 marks)

Workflow

1. **Scope and authorize:** record incident ID, system owner, time window, evidence sources, and questions.

2. **Preserve:** follow incident-response direction, preserve volatile evidence when appropriate, document actions, and avoid unnecessary interaction with original media.

3. **Acquire and verify:** record tool/version, operator, time/timezone, source, and SHA-256; verify the working copy.

4. **Analyze:** review account/logon records, OS logs, browser history/downloads, recent files, shell/command history where available, scheduled tasks/services, USB artifacts, persistence locations, archives/executables, and security logs.

5. **Build timeline:** normalize timestamps while retaining originals; correlate logons, file events, process execution, downloads, and network activity.

6. **Correlate:** use independent sources for important claims. A timestamp alone does not prove a user intentionally opened or executed a file.

7. **Assess impact:** identify affected accounts/systems and possible access/modification only when supported.

8. **Report:** document evidence IDs/hashes, methods, confidence, limitations, and recommendations.

Evidence versus assumption

| Type | Example | Treatment |

| --- | --- | --- |

| Direct observation | Autopsy lists a browser download record at `[actual time]` | Cite artifact ID |

| Correlation | Download record and execution-related log occur in same time window | State correlation and limits |

| Hypothesis | User may have run the downloaded file | Label as hypothesis until corroborated |

| Unsupported claim | “User stole data” without supporting artifact | Do not state as a finding |

Additional evidence to request

• Original disk image and acquisition notes.

• Endpoint detection/antivirus logs.

• OS event logs or Linux authentication/system logs.

• Firewall, DNS, VPN, proxy, and network flow logs.

• Identity-provider/account audit logs.

• Email security logs and original suspicious message/attachment.

• Cloud/SaaS audit logs where relevant.

• Time synchronization/timezone configuration and known-good baseline.

Incident finding template

Finding ID: IR-01

Question: `[specific question]`

Evidence: `[artifact IDs, hashes, timestamps, sources]`

Observed facts: `[directly supported statements]`

Assessment: `[confirmed / likely / inconclusive]`

Alternative explanations: `[plausible alternatives]`

Impact: [supported impact only]

Actions: [containment/remediation/monitoring]

Limitations: [missing sources, time gaps, clock uncertainty]

This is the requested investigation workflow, not a claim that a real incident was proven.

10. Overall Findings Summary

ID	Area	Conclusion	Severity/status
Q1-01	SQLi	Boolean-style input returned multiple records; behavior consistent with SQLi	High, provisional
Q2-01	XSS	Harmless script caused alert in lab	Medium–High, context-dependent
Q3-01	API recon	Documentation found and lab objective completed	Informational/Low unless sensitive exposure is evidenced
Q4	Authorization	Lab reportedly completed; exact request/response unavailable	Unconfirmed
Q5	API controls	Test plan prepared; no outcomes claimed	Not rated
Q6	Forensics	Image unavailable; no findings asserted	Pending evidence
Q7	Incident workflow	Methodology provided; no real incident conclusion	Scenario response

11. Recommendations

1. Parameterize SQL queries and apply least-privilege database access.
2. Use context-aware output encoding, safe DOM APIs, and CSP defense in depth.
3. Enforce object-level authorization on every API operation.
4. Validate request schemas, allow-list fields, rate-limit sensitive operations, and minimize response data.
5. Preserve forensic originals, verify hashes, maintain custody notes, and correlate artifacts before conclusions.
6. Keep all testing within authorized labs.
7. Attach genuine screenshots and sanitized HTTP evidence; do not use online tool screenshots as substitutes for your own evidence.

12. Evidence Index

Add real screenshots only:

- `Q1_01_baseline_search.png`
- `Q1_02_single_quote_error.png`
- `Q1_03_boolean_test.png`
- `Q2_01_payload_input.png`
- `Q2_02_alert_execution.png`
- `Q3_01_api_documentation.png`
- `Q3_02_endpoint_request_response.png`
- `Q3_03_lab_completion.png`
- `Q4_01_userA_baseline_request.png`
- `Q4_02_modified_object_id.png`
- `Q4_03_comparison_response.png`
- `Q5_01_controlled_test_matrix.png` (only if tests were run)
- `Q6_01_autopsy_case_overview.png`
- `Q6_02_autopsy_artifact_details.png`
- `Q6_03_autopsy_timeline.png`
- `Q6_04_hash_verification.png`
- `Q7_01_incident_timeline.png`

Do not include empty placeholders as if they were screenshots. If a screenshot was not captured, mark it unavailable or capture it before submission.

13. References

1. PortSwigger API testing: https://portswigger.net/web-security/api-testing

2. PortSwigger access control: https://portswigger.net/web-security/access-control

3. API documentation lab: https://portswigger.net/web-security/api-testing/lab-exploiting-api-endpoint-using-documentation

4. User ID controlled by request parameter lab:
https://portswigger.net/web-security/access-control/lab-user-id-controlled-by-request-parameter

5. Autopsy Quick Start Guide: https://sleuthkit.org/autopsy/docs/user-docs/4.12.0/quick_start_guide.html

6. Autopsy Ingest Modules: https://sleuthkit.org/autopsy/docs/user-docs/4.21.0/ingest_page.html

7. Autopsy Timeline: https://sleuthkit.org/autopsy/docs/user-docs/4.16.0/timeline_page.html

8. Autopsy official website: https://www.autopsy.com/

Final checklist

- [ ] Replace student/program/date placeholders.
- [ ] Add genuine Q1/Q2 screenshots and exact URL/parameter details.
- [ ] Add Q3 endpoint and request/response evidence.
- [ ] Add Q4 request/response pair; claim a flaw only if cross-user access is proven.
- [ ] Run any Q5 tests only in the authorized lab and report observed outcomes.
- [ ] Request the instructor forensic image/logs; never invent hashes, timestamps, or artifacts.
- [ ] If the image is unavailable by the deadline, clearly disclose Q6 as pending evidence.
- [ ] Remove passwords, session cookies, tokens, and unrelated personal data from screenshots.